



BSI Standard 200-1

VMware Cloud Foundation 9.1

June 23, 2026

Table of Contents

Disclaimer.....3

Version.....4

Introduction.....4

Additional Resources4

Third Party Identifiers and Mappings4

Coverage Levels4

Controls..... 6

Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided “AS IS.” Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

Version

910-20260623-01

Introduction

This document describes how VMware Cloud Foundation (VCF) 9.1 and the separately licensed advanced services assessed alongside it, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, and VMware Avi Load Balancer, can support organizations working toward alignment with BSI Standard 200-1. BSI Standard 200-1, published by the German Federal Office for Information Security (BSI), defines general requirements for an information security management system (ISMS) and is compatible with ISO/IEC 27001. It addresses management principles, resources, the security process, the security concept, and ISMS certification. Each assessed product is reported separately for every control, with VCF covering the full platform, including its consumption services and Private AI Services capabilities. The responsibility for establishing and operating an ISMS in accordance with BSI Standard 200-1 remains with the organization.

https://www.bsi.bund.de/EN/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/BSI-Standards/bsi-standards_node.html

This guidance evolves. Please check the current revision at: <https://brcm.tech/vcf-compliance>

Additional Resources

This is one of a library of companion guides that map VMware Cloud Foundation and its advanced services to security and compliance frameworks. For each framework, the guide is published as a spreadsheet, a CSV data file, a Markdown document, and a PDF, together with a Security Configuration Guide crosswalk that identifies the VCF technical hardening settings relevant to that framework. The companion guide library, the VMware Cloud Foundation Security Configuration Guide, and related security documentation, sample scripts, and Q&A are available at <https://brcm.tech/vcf-security>.

Third Party Identifiers and Mappings

This document includes regulatory compliance and security control identifiers from external sources as a convenience to end users. This does not constitute endorsement, in either direction.

There is not a one-to-one mapping of product capabilities to third-party controls. A product capability, or set of capabilities, may be applicable to multiple controls. Conversely, a control may be satisfied with the use of multiple capabilities.

Control identifier numbers have been included from the Secure Controls Framework, version 2026.1, under the terms of the Creative Commons Attribution-NoDerivatives 4.0 International Public License. No modifications have been made to the control identifier numbers under the terms of the license.

<https://securecontrolsframework.com/>

Coverage Levels

Each control entry below carries the framework control text, the SCF control or controls it maps to, and an Aggregate Coverage line showing the strongest position any one of the assessed products holds for that control. Products that meet or contribute to the control follow as subsections, each with its own coverage level and response. Products the control does not apply to are listed together at the end of the entry, with a brief explanation. The coverage levels are:

- **Meets** -- the product directly provides the capability described in the control. No additional organizational process, external product, or human activity is needed beyond configuring the product itself.
- **Contributes** -- the product provides technical capabilities that help satisfy the control, but the control also requires something outside the product to be fully met, such as an organizational process, human activity, or an additional tool.

- **Not Applicable** -- the control does not apply to the product. Physical facility controls, staffing decisions, organizational governance processes, and domains the product does not operate in fall here.
- **Not Supported** -- the control is relevant to the product's domain (infrastructure, networking, security), but the product lacks the specific capability the control requires.
- **Not Assessed** -- the control has not yet been evaluated against the product.

Controls

Control 4.1.1

Assumption of overall responsibility for information security: The topmost management level of every government agency and company is responsible for the organisation working in a targeted and proper manner and is therefore also responsible for assuring information security both on the inside and out. Depending on the country and type of organisation, this can also be governed by various laws.

SCF Controls: GOV-01.1, GOV-04

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 4.1.2

Initiating, managing, and supervising information security: The topmost management level must initiate, manage and supervise the security process. This, for example, involves the following tasks: - • A strategy for information security and security objectives must be agreed upon and communicated.

SCF Controls: GOV-01, GOV-01.1, PRM-01.1, PRM-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 4.1.3

Integration of information security: Information security is a cross-sectional function and must therefore be integrated in all processes and projects of the organisation processing information. Examples of this include: - • project management: already in the planning phase of a project, the protection requirements of the information to be processed in the future as a result must be assessed and, building thereon, suitable security safeguards must be planned.

SCF Controls: GOV-01, GOV-14, GOV-15, IRO-01, PRM-01, PRM-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 4.1.4

Setting objectives that can be achieved: Projects frequently fail because the objectives that have been set are unrealistic or too ambitious. This is no different in the field of information security.

SCF Controls: PRM-01, PRM-04, PRM-05, PRM-06

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 4.1.5

Pondering security costs against benefits: One of the most difficult tasks is to ponder the costs for information security against the benefits and risks. It is very important to initially invest in safeguards that are particularly effective or provide protection against especially high risks.

SCF Controls: PRM-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 4.1.6

Role model function: The management level must assume a role model function also when it comes to information security. Among other things, this includes that the management level takes into account all specified security rules, participates in training measures, and supports other managers regarding the execution of their role model function.

SCF Controls: GOV-04, GOV-04.1, GOV-04.2

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 4.2

Communication and knowledge: Communication is an important cornerstone regarding the achievement of the set security objectives in all phases of the security process. Misunderstandings and lack of knowledge are the most common causes for security issues.

SCF Controls: HRS-03.1, SAT-03.6, THR-03.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 4.3

Performance review within the security process: The management level must regularly check the performance and assess the security process (management assessment). If required (e.g.

SCF Controls: GOV-01.1, GOV-01.2, GOV-05

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 4.4

Continuous improvement of the security process: The results of the performance review must be used consistently to make appropriate corrections. This might mean that the security objectives, the security strategy, or the security concept must be changed and the security organisation must be adapted to the requirements.

SCF Controls: GOV-01.1, GOV-01.3

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 5

Resources for information security: Maintaining a particular level of security always requires financial, personnel, and time-related resources that must be made available in sufficient quantities by the management level. If set objectives cannot be achieved due to a lack of resources, it is not the fault of the persons responsible for the implementation, but rather the fault of the superiors who have set unrealistic objectives or have not provided the necessary resources.

SCF Controls: PRM-01, PRM-02

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 6

Involving employees in the security process: Information security affects all employees without any exceptions. By acting responsibly and with quality awareness, every individual can avoid damages and contribute to success.

SCF Controls: HRS-01, HRS-01.1, HRS-02, HRS-03.1, SAT-01, SAT-01.1, SAT-02, SAT-03, SAT-03.6

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 7

The security process: The management level must define the security objectives knowing all of the relevant framework conditions, the environmental analysis, and based on the business objectives of the company or the role of the government agency and must create the prerequisites for their implementation. The approach is planned with a security strategy to establish a continuous security process.

SCF Controls: PRM-01, PRM-01.1

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 7.1

Planning of the security process: The creation of information security is not an end in itself, but information security contributes to the objectives of an organisation being achieved and being able to reliably execute business processes and tasks. For this, it is required that the organisation identifies and analyses all framework conditions, defines the security objectives, and draws up a security strategy containing basic statements on how the set objectives should be achieved.

SCF Controls: GOV-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 7.2

Establishing a security organisation: Planning and executing a security process includes defining organisational structures (e.g. departments, groups, centres of expertise) as well as roles and duties.

SCF Controls: GOV-04, GOV-04.1, GOV-04.2, HRS-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 7.3

Implementation of the information security policy: A security concept must be drawn up in order to achieve the set security objectives. For greater clarity, a separate chapter has been provided to explain how a security concept can be planned and implemented and how the level of information security can be maintained and improved.

SCF Controls: GOV-02, GOV-03

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 7.4

Maintaining information security: Establishing information security is not a project with a limited time span, but a continuous process. The appropriateness and effectiveness of all elements of the information security management system must be checked at regular intervals.

SCF Controls: CPL-01.1, CPL-02.1, GOV-01.1, GOV-01.3

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 7.5

Continuous improvement of information security: Ultimately, the review of the security process is intended to improve the process. The results should therefore be used to assess the effectiveness and efficiency of the selected security strategy and, if necessary, to adapt it.

SCF Controls: GOV-01.1, GOV-01.2, GOV-01.3

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 8.1

Creating a security concept: To fulfil the information security objectives and achieve the desired level of security, an understanding regarding how the fulfilment of tasks and business processes depends on the confidentiality, integrity, and availability of information must initially be developed. For this, it must also be considered which damage causes such as force majeure, organisational shortcomings, human error, or also cyber risks threaten the business processes.

SCF Controls: GOV-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 8.2

Implementation of the security concept: Once the security safeguards have been selected they must be implemented according to an implementation plan. The following steps should be followed during implementation: Development of an implementation plan for the security concept [DOC] An implementation plan must include the following subjects: - • specification of priorities (implementation sequence), - • specification of responsibilities for initiation, - • provision of resources by the management, and - • implementation planning of individual safeguards (definition of dates and costs, definition of persons in charge of implementation, as well as persons in charge of supervising the implementation and the efficiency of safeguards).

SCF Controls: GOV-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 8.3

Performance review of the security concept: In order to maintain the level of security, the security safeguards identified as being appropriate must be applied on the one hand and, on the other hand, the security concept must be updated continuously. Furthermore, security incidents must be detected in due time and quick and appropriate reactions to these are required.

SCF Controls: GOV-01

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 8.4

Continuous improvement of the security concept: Regularly reviewing the performance of the security concept serves for remedying errors and vulnerabilities identified and for optimising security safeguards with regard to their efficiency. One important item involves improving the practical feasibility of technical safeguards and organisational procedures so as to increase the acceptance of the security safeguards.

SCF Controls: GOV-01.1, GOV-01.2, GOV-01.3

Aggregate Coverage: Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

Control 9

Certification of the ISMS: The successful design and operation of an ISMS are not an easy task. If this task has been performed successfully, it is practicable to document this both internally and externally and to render transparent the successful efforts in the field of information security.

SCF Controls: CPL-01.3, CPL-01.4

Aggregate Coverage: Contributes

VCF (Contributes)

VCF provides built-in compliance measurement, scoring, and reporting capabilities that support an organization's conformity assessment activities. These tools allow operators to evaluate the state of their VCF environment against established security benchmarks and internal policies, producing quantitative results that can feed into broader compliance assessment programs. While conducting a full compliance program assessment is an organizational responsibility, VCF provides the technical instrumentation needed to assess and report on infrastructure conformity.

VCF Operations includes a compliance scoring engine that measures how well objects in the environment conform to industrial, governmental, regulatory, or internal standards, including the DISA STIG. The compliance score is calculated as the ratio of compliant objects to the total number of objects assessed by a given benchmark, expressed as a percentage. When an object violates multiple standards, the compliance score reflects the most critical violation, so the worst-case posture is visible. The compliance score card displays 100 when all objects are compliant, and shows the count of non-compliant symptoms when violations exist. The Badge|Compliance metric provides a per-object compliance percentage based on triggered symptoms versus total symptoms. Compliance scores are calculated for all objects in the environment regardless of the viewing user's object-level permissions, so the assessment reflects the true state of the environment rather than a filtered view.

VCF Operations compliance management detects violations, highlights risk areas, and provides actionable remediation recommendations. Compliance alerts appear as violations to the standard, and the triggered symptoms appear as violated rules. The Compliance Alert List displays alerts that caused compliance violations in a sortable table, allowing administrators to prioritize remediation efforts. These alerts, combined with remediation guidance, help administrators move from assessment findings to corrective action.

NSX provides a compliance report capability that allows administrators to compare their NSX networking configuration against IT policies and industry standards. This report identifies areas where the configuration deviates from the selected benchmark, supporting targeted remediation as part of an assessment cycle.

At the VMware vCenter level, the Compliance interface compares the desired configuration state against the current state of each host in a cluster and calculates drift. The ClusterCompliance or HostCompliance object returned by the compliance check API contains the per-host compliance status, notifications, and check duration, and administrators can retrieve cluster compliance status through the REST API by calling the Compliance.get endpoint. This mechanism checks conformity with the cluster's configured desired state rather than with a regulatory benchmark directly, but when the desired state profile is built to match a regulatory baseline, the drift check supports ongoing assessment against that baseline.

VCF's security configuration guidance, including the Security Configuration Guide and the DISA STIG, provides prescriptive baselines that organizations can use as the reference standard for their conformity assessments. VCF supports compliance measurement against guidelines for protecting controlled unclassified information. Administrators can automate assessment and remediation workflows through product interfaces, command-line tools, and APIs, reducing the manual effort involved in preparing for and responding to compliance assessments. VCF Operations also supports running workflows to remediate alerts or automate tasks, and maps out-of-the-box workflows to recommendations for automated remediation.

These capabilities allow organizations to run repeatable, evidence-based conformity assessments against their VCF infrastructure, but the broader assessment program, including determining which laws, regulations, and contractual

obligations apply, selecting assessment frameworks, scheduling assessment cycles, engaging independent auditors where required, and acting on assessment findings, remains an organizational responsibility.

VMware vDefend (Contributes)

VMware vDefend contributes to conformity assessments through Security Services Platform's Security Segmentation scoring and assessment capabilities, which provide measurable, evidence-based evaluation of an organization's network microsegmentation posture.

Security Services Platform calculates a Security Segmentation Score on a 100-point weighted scale distributed across five categories. Points are awarded only when firewall rules and configuration meet specified requirements, giving compliance officers a quantitative metric to track microsegmentation maturity over time. The scoring system supports Relaxed mode, useful for gauging progress during segmentation implementation, and Strict mode, which applies stricter penalties for unidentified or unsegmented traffic for more stringent posture assessment. These modes allow organizations to choose the assessment rigor appropriate to their compliance posture.

Environment Protection assessment evaluates whether workloads are protected by environment-specific segmentation policies, such as Dev, Prod, and Test. It measures the percentage of environment pairs operating in blocked mode and the percentage of all workloads covered by at least one environment rule, providing concrete metrics that can be presented during conformity assessments. The Security Segmentation Report includes an Inter-Environment Pair Protection Rule Action Summary section that provides a tabular summary of inter-environment communications, suitable for inclusion in audit evidence packages.

The Security Segmentation Score Breakdown report provides more granular detail, listing total environments and pairs, protection rule action summaries, and identifying environment pairs that lack inter-environment policies. This breakdown allows auditors to pinpoint specific gaps in microsegmentation coverage rather than relying solely on the aggregate score.

Rule Analysis, available within Security Services Platform, supports scheduled or on-demand analysis of the complete VMware vDefend (DFW) configuration. It detects contradictions where two rules have the same configuration with different actions, and identifies shadowed rules by comparing effective group memberships. Rule Analysis results can be exported as a CSV report for archival and review by external assessors. Role-based access control for Rule Analysis is enforced through Security Services Platform's platform roles; Enterprise Admin has full access to run, view, and download Rule Analysis reports. These capabilities help organizations demonstrate that their firewall policy is internally consistent and that analysis artifacts are available for auditor review.

Security Intelligence, integrated within Security Services Platform in VMware vDefend, provides policy recommendations that can be reviewed, modified, and published to enforce network security policies. The View Impacted Flows capability displays unprotected traffic flows used to generate policy recommendations, giving auditors direct visibility into unprotected network paths.

These vDefend capabilities address the network security dimension of conformity assessments. The broader compliance assessment program, including determining which regulations apply, selecting assessment frameworks, engaging assessors, and evaluating non-network controls, remains an organizational responsibility outside the scope of vDefend.

VCF Protection and Recovery (Contributes)

VCF Protection and Recovery (PNR) generates technical artifacts and supports compliance-oriented subscription tiers that organizations can use as evidence when demonstrating conformity with disaster recovery and data protection requirements. PNR does not include a dedicated compliance management engine, framework mapping capability, or benchmark scoring system.

The Advanced Cyber Compliance subscription, sold as a VCF advanced service, provides on-premises data protection and recovery capabilities designed for regulated environments. Advanced cyber protection and recovery capabilities within PNR require an Advanced Cyber Compliance per-core license in addition to VCF core capabilities, and an Advanced Cyber Compliance subscription is required to configure remote snapshots. The existence of this compliance-tier subscription reflects PNR's intended use in environments subject to regulatory and contractual data protection obligations.

Protection groups and recovery plans constitute documented configurations that must be verified for connection and validity. These configurations identify which workloads are protected and the recovery objectives assigned to each workload. Maintaining verified protection groups and recovery plans produces artifacts that organizations can present to demonstrate that DR procedures are defined and operational.

The Clean Room Orchestrator generates Events representing observations and issues raised by the system, providing information about situations that require attention or action. This event stream contributes to the operational audit record for recovery environment activities.

Identifying which laws and regulations apply, mapping controls to requirements, and managing the overall compliance program are organizational responsibilities outside the scope of PNR.

VMware Data Services Manager (Contributes)

VMware Data Services Manager (DSM) contributes to an organization's ability to demonstrate conformity through several mechanisms: enforceable data service policies, per-policy compliance reporting, infrastructure policy guardrails with compliance alerting, configurable backup and retention controls, and audit event logging.

DSM supports the creation and enforcement of data service policies that define organizational standards for database deployments, including PostgreSQL, MySQL, SQL Server, and MinIO databases. Administrators configure these policies and assign them to one or more organizations or tenants, creating a documented, repeatable configuration baseline. When integrated with VCF Automation, these policies can be enforced consistently across tenants to maintain a uniform security and compliance posture. Policy definitions can be tailored to specific organizational requirements, providing an auditable record of the standards applied to each tenant. The Infrastructure Policies view in the DSM dashboard provides visibility into which policies are active and which databases are associated with them.

DSM provides a compliance report for each data service policy that displays policy violations, noncompliant databases, data services, and namespaces, giving administrators a structured view of deviations from defined organizational standards. DSM also generates infrastructure policy compliance alerts that allow administrators to monitor whether clusters are operating in conformance with defined infrastructure policies. Infrastructure policies create guardrails that restrict the quality and quantity of resources DSM users can consume from vSphere clusters, providing a mechanism for documented resource governance that can be presented to auditors as evidence of enforced controls.

For resilience conformity, DSM supports automated database backups with configurable schedules (full and incremental), configurable retention periods, and configurable storage locations using S3-compatible object stores, local storage, or cloud targets. DSM retains automated backups of deleted databases until the configured retention policy is met, and administrators can edit the retention period for retained backups. Backups can be enabled or modified after database creation via the automated-backups setting. Control plane backups are stored in S3 object storage with unique identifiers corresponding to the control plane ID. Backup operations are logged at the error level to both console and file outputs, providing an operational audit trail for backup activity. These capabilities allow an organization to demonstrate that database resilience controls are in place and configured within defined parameters.

Demonstrating conformity to applicable laws, regulations, or contractual obligations requires organizational processes beyond what DSM provides directly. Organizations must map DSM's configuration and operational evidence to the specific requirements of applicable frameworks, collect and maintain that evidence, and manage formal attestation processes. DSM provides technical controls and configuration visibility that form part of the evidentiary foundation, but formal compliance documentation, evidence management, and audit reporting remain organizational responsibilities.

VMware Avi Load Balancer (Contributes)

VMware Avi Load Balancer (Avi) provides configuration export, backup management, and auditable policy artifacts that organizations can use when demonstrating security capability conformity for their application delivery infrastructure.

The Avi Controller CLI includes an export command to capture the full system configuration or an individual virtual service configuration. These exports document the security settings, WAF policies, and access control rules in effect at the time of capture and can be retained as part of a compliance documentation package. In VCF deployments, VCF Operations is used to

configure the external backup server and storage path for Avi Load Balancer backups, and backups are stored on the same server as VCF Operations appliance backups by default. For deployments where the Controller runs as a single node, enabling periodic external configuration backups is a mandatory requirement to handle recovery in the case of a complete VM or disk failure.

Configuration backup files can be protected with a passphrase, keeping audit artifacts secure in storage. When a restore is performed, the Controller requires that the passphrase match the one used when creating the backup, validates that all file objects from the backup configuration are present before the restore can proceed, and verifies that the FIPS mode of the backup configuration matches the controller environment. This set of integrity checks supports the reliability of configuration records used as audit documentation.

For application security evidence, Avi's WAF Positive Security model allows administrators to define and document allowed application behavior through explicit policy rules, forming part of the evidence set for application security controls. Avi also provides User-Defined Metrics, which allow administrators to define and extract customized telemetry data required for specific compliance or reporting needs via API calls.

On the administrative access side, Avi supports role-based access control with object-level permissions that can be applied to roles and inherited by user groups. The ability to export certificates and private keys is restricted to the fewest number of administrators possible. The Auth Mapping Profile feature supports LDAP group match rules and attribute-based role assignments, enabling a verifiable access control posture that can be reviewed during an audit.

